

핀테크서비스 취약점 점검 안내서 [오픈뱅킹]

2026. 2.



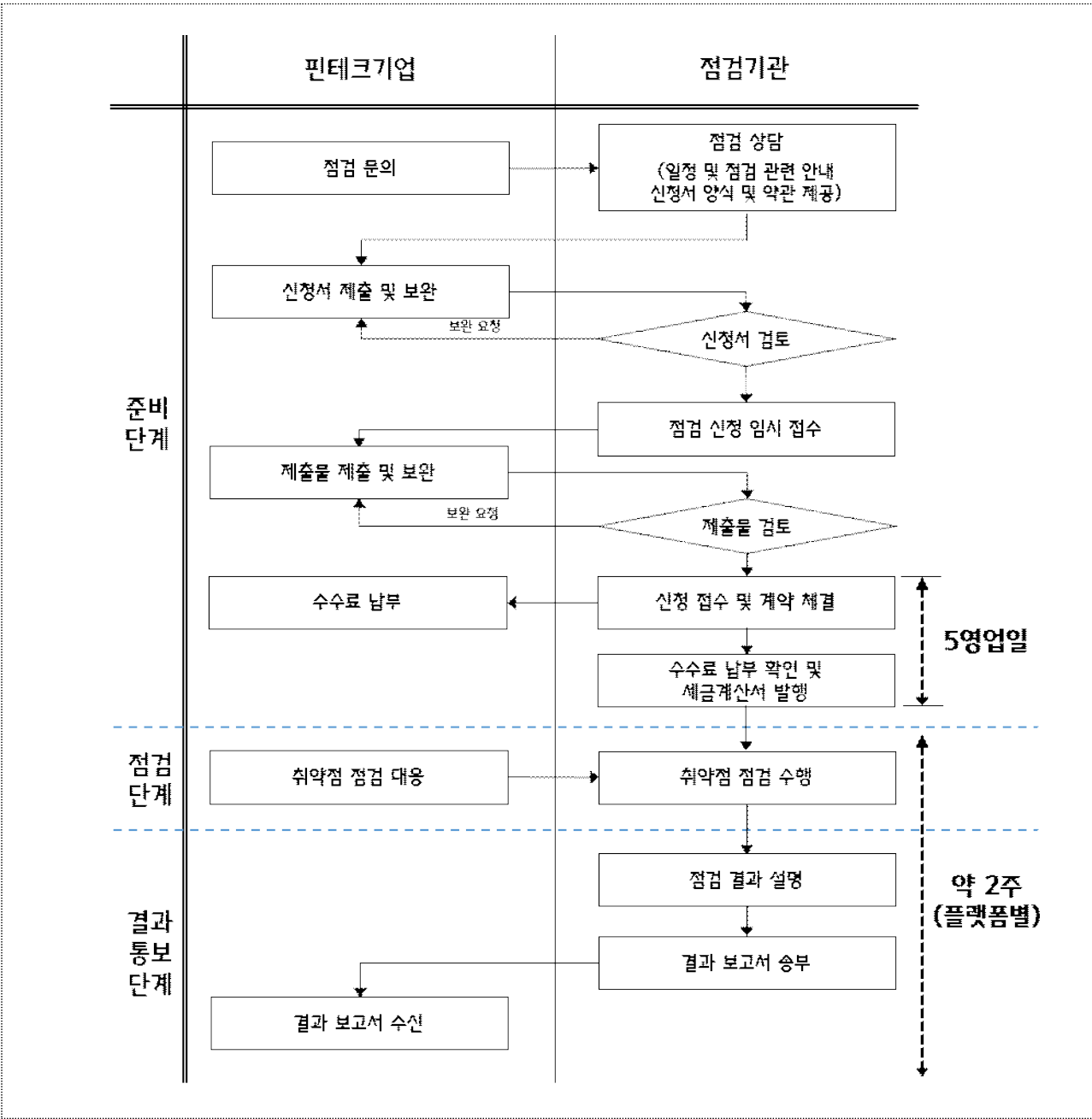
금융보안원
FINANCIAL SECURITY INSTITUTE

1. 개요

- ☐ (점검 내용) 오픈뱅킹을 이용하는 핀테크서비스 애플리케이션(앱/웹)에 대한 취약점을 점검
- ☐ (소요 기간) 착수 후 약 2주 이내(플랫폼 별)
- ☐ (점검 항목) 플랫폼 별로 점검항목을 분리하여 점검 수행
 - (웹) 5개 분야, 12개 항목, 38개 세부항목
 - (모바일) 6개 분야, 17개 항목, 46개 세부항목
 - ※ '오픈뱅킹 보안' 분야 추가, 「(참고) 핀테크서비스 취약점 점검항목」 참고
- ☐ (점검 종류)
 - (신규점검) 모든 점검항목을 기반으로 수행하는 통상적 형태의 점검으로, 오픈뱅킹을 이용하고자 하는 핀테크서비스를 대상으로 오픈뱅킹 이용 핀테크서비스 실시 전 점검
 - (재점검) 이전 점검에서 발견된 미흡사항 및 변경사항 등에 중점을 두어 수행하는 점검으로, 주로 보완조치 이행 여부 및 변경사항에 대한 취약점 유무를 점검
 - (사후점검) 취약점 점검을 완료하여 오픈뱅킹을 이용하는 핀테크서비스에 대하여 지속적인 안전성을 확보할 수 있도록 정기 또는 수시로 수행하는 점검으로, 모든 점검항목을 기반으로 수행하는 통상적 형태의 점검
 - ※ 사후점검에 대한 세부사항은 오픈뱅킹 운영기관에서 별도 안내

2. 점검 절차

《 핀테크서비스 취약점 점검 절차 》



1 준비 단계

- ① (점검 상담) 점검을 신청하고자 하는 핀테크 기업은 점검기관에 점검가능 여부, 점검 일정, 제출물 등을 문의 및 상담
- ② (점검 신청) 핀테크 기업은 핀테크 보안점검 관리시스템(fintech.fsec.or.kr)에 가입 후 신청서를 제출하고, 점검기관은 필요한 제출물을 요청
 - 2개 이상의 플랫폼에 대해 점검을 신청할 경우 플랫폼 별로 신청서 제출
※ 예) 신청 플랫폼이 WEB, Android, iOS일 경우 총 3번 신청서 제출
- ③ (제출물 제출) 핀테크 기업은 점검 기관이 요청한 제출물을 핀테크 보안점검 관리시스템에 제출하여 검토를 의뢰하고, 점검기관은 이를 검토

제출물	구분	설명
점검 대상	웹	- 점검을 요청 하는 (운영망 or 스테이징/개발) 서비스 URL
	모바일 (Android/iOS)	- 보안모듈이 모두 적용된 설치파일 - 보안모듈*이 일부 제외된 설치파일 * 루팅/탈옥 탐지, SSL Pinning 등
부가 정보	테스트 계정	- 테스트망일 경우, 별도 계정으로 이용해야 할 경우 이용자 정보가 구분된 2개 이상의 계정 정보 제출
	테스트 계좌번호	- 테스트망에서, 오픈뱅킹 계좌 연결을 위한 계좌 번호로 이용자 정보가 구분된 2개 이상의 계좌 번호 제출
	정보기술서	- 오픈뱅킹 이용 전반에 관한 내용으로, 보안점검 관리 시스템에 공개된 양식에 맞추어 가입 후 제출
	ISMS, ISMS-P 인증서	- 사후 점검 시, ISMS/ISMS-P 인증을 보유하고 있을 경우 해당 보유 여부에 대한 인증 증빙 자료 제출
	확약서	- 운영망 점검 시, 점검 관련 확약서 제출
	기타 사항	- 기타 점검 시 요청 사항 등은 점검 관리 시스템의 상담 게시판 및 점검 화면의 댓글을 통해 제출

※ 보안모듈 적용·미적용된 설치파일 제공이 미흡할 경우 점검 취소(환불 불가), 미확인 점검 항목 모두 미흡 처리 등의 불이익이 발생

- ④ (점검 접수 및 계약) 점검기관은 신청서를 접수하고, 계약을 체결(점검일정 확정). 신청기관은 수수료* 납부(5영업일 이내**)

* 재점검의 경우 재점검 신청항목 개수에 따라 수수료 차등

** 5영업일 내 수수료 납부가 불가능할 경우 납부 지연 사유 및 납부 예정 일자에 대한 공문 발송 필요

2 점검 단계

- 점검기관은 핀테크 기업의 제출물을 토대로 취약점 점검을 수행*
 - 점검 기간 동안 핀테크 기업은 점검 대상(클라이언트 및 서버의 소스코드, 웹서버 설정 등)에 대한 변경·보완 불가**
- * 점검 진행이 어려운 환경인 경우 핀테크 기업에 추가적인 조치(프록시 탐지 기능 제외, Frida 탐지 기능 제외 등)를 요청할 수 있으며 핀테크 기업은 원활한 점검을 위해 수용 필요
- ** 점검 기간(결과 통보 전) 중 점검 대상에 변경·보완이 발생한 경우 관련 항목을 모두 취약한 사항으로 판단

3 결과 통보 단계

- ① (결과 확인) 점검 기관은 점검 종료 후 점검 결과의 초안 확인을 요청*하고 핀테크 기업은 점검 결과에 대한 내용 확인
- * 초안 요청일을 기준으로 7영업일 동안 핀테크 기업에서 점검결과에 대한 문의 및 확인 과정이 없을 경우 점검결과를 확정하고 결과 통지 절차 진행
- ※ 핀테크 기업의 문의에도 오픈뱅킹 운영 및 점검 기준상 결과의 변경 여지가 없을 경우, 초안 요청일을 기준으로 10영업일 이후 결과 확정 및 통지 절차 진행
- ② (결과 통지) 점검기관은 핀테크 기업에 최종 결과보고서를 송부

3. 문의

- 금융보안원 DT평가팀
 - (연락처) 02-3495-9888
 - (이메일) fintech_check@fsec.or.kr

※ 일부 점검 항목의 세부 기준은 핀테크 보안점검 관리시스템의 FAQ상에 공개되어 있으므로 함께 확인 해주시기 바랍니다.

1. 웹(Web)

분야	점검항목	세부 점검항목	점검항목 설명	주요 취약점 발생 사례
중요정보 ^{주)} 보호	메모리 내 노출 방지	메모리 내 중요정보 평문 노출 확인	☐ 단순 로그인* 외 중요정보 입력 또는 처리 과정 등**에서 메모리 내 평문(또는 쉽게 평문으로 변환 가능한 문자열) 노출 여부를 점검 * 웹 애플리케이션 최초 메뉴 진입을 위한 로그인(전자금융거래의 직접적인 처리와 무관) ** 예) 주민등록번호 입력, 간편결제 비밀번호 입력 등	- 간편결제 비밀번호 입력 시 메모리 내 비밀번호가 평문 형태 또는 복호화가 가능한 인코딩 방식(예: Base64 등)으로 노출되는 경우 - 주민등록번호 전송 이후 메모리 내 주민등록번호가 평문 형태 또는 복호화가 가능한 인코딩 방식(예: Base64 등)으로 노출되는 경우 - 중요정보가 포함된 파일(주민등록증, 운전면허증 등) 전송 이후 메모리 내 파일 원본 또는 복호화가 가능한 인코딩 방식(예: Base64 등)으로 존재하는 경우 - 오픈뱅킹 이용 시 메모리 내 오픈뱅킹 관련 중요정보(access_token, client_secret 등)가 평문 형태 또는 복호화가 가능한 인코딩 방식(예: Base64 등)으로 노출되는 경우
	웹 영역 내 노출 방지	웹 영역 내 중요정보 평문 노출 확인	☐ 중요정보의 입력 또는 처리 과정 등에서 HTML, Javascript, DOM 등 웹을 표현하기 위한 영역 내 평문(또는 쉽게 평문으로 변환 가능한 문자열) 노출 여부를 점검	- 전자금융거래 관련 비밀번호 입력 시 DOM 영역 내 비밀번호가 평문 형태 또는 복호화가 가능한 인코딩 방식(예: Base64 등)으로 노출되는 경우(예: Chrome 개발자도구 >Console> document.getElementById('<input tag id>').value) - 클라이언트 스크립트 내 평문 형태 또는 복호화가 가능한 인코딩 방식(예: Base64 등)으로 하드코딩된 오픈뱅킹 관련 중요정보(access_token, client_secret 등)가 노출되는 경우
	파일 내 노출 방지	파일 내 중요정보 평문 저장 확인	☐ 이용자 PC에 저장되는 핀테크서비스 관련 파일 내 중요정보의 평문 저장 여부를 점검	- 로그인 시 계정정보가 PC 내 파일에 평문 또는 복호화가 가능한 인코딩 방식(예: Base64 등)으로 저장되는 경우 - 신분증 업로드 완료 후 신분증 이미지 파일이 원본 형태로 저장되는 경우
	화면 내 노출 방지	화면 내 중요정보 평문 노출 확인	☐ 중요정보의 화면 내 평문(원본*) 노출 여부 및 화면 캡처를 통한 탈취 가능 여부를 점검 * 본인인증을 위해 신분증 이미지파일을 업로드하는 경우, 신분증에 기재된 중요정보가 마스킹되지 않은 원본 이미지를 의미	- 주민등록번호 입력 시 뒷자리가 평문으로 노출되며 화면 캡처가 가능한 경우 - 신분증 업로드 시 주민등록번호가 표시된 원본 이미지가 출력되며 화면 캡처가 가능한 경우
	중요정보 암호화 전송	중요정보 송수신시 보호대책 적용 확인	☐ 데이터 송수신시 중요정보가 평문(또는 쉽게 평문으로 변환 가능한 문자열, 신분증 등 중요정보가 포함된 이미지, JWT 등)으로 노출되는 것을 방지하기 위한 보호기능 적용 여부를 점검	- 중요정보 처리 요청/응답 시 패킷 내 중요정보가 평문 또는 복호화가 가능한 인코딩 방식(예: Base64 등)으로 전송되는 경우 - 이용자 인증 시 오픈뱅킹 관련 중요정보(access_token, client_secret 등)가 네트워크 구간에 암호화가 미적용 되어 있는 경우 - 중요정보에 해당되는 이미지 처리 시 패킷 내 중요정보가 포함된 이미지가 평문 또는 복호화가 가능한 인코딩 방식(예: Base64 등)으로 전송되어 해당 이미지를 추출할 수 있는 경우

주) 오픈뱅킹 관련 중요정보(오픈뱅킹 인증키(client_secret), 오픈뱅킹 접근키(access_token) 등), 이용자 중요정보(고유식별정보, 비밀번호(로그인 비밀번호, 거래 비밀번호 등), 연계정보(CI, Connecting Information)가 다른 정보와의 결합 가능성이 있는 경우, 기타 중요 인증정보 등) 등

분야	점검항목	세부 점검항목	점검항목 설명	주요 취약점 발생 사례
	네트워크 구간 암호화 적용	안전한 HTTPS 적용 확인	☐ 송·수신되는 중요정보를 보호하기 위해 통신구간 암호화(HTTPS) 적용 여부를 점검 ☐ 취약한 HTTPS 정책 사용 여부를 점검 ※ 취약한 HTTPS 정책 확인 및 조치 시 HTTPS 정책 검증 도구 (https://ssllabs.com, testssl 등) 참고	- 전자금융거래 관련 중요정보 전송 시 통신구간 암호화(HTTPS)가 미적용 되어있는 경우 - 서버 인증서의 유효기간이 만료되어 경고를 출력하는 경우 - 인증서의 "서명 알고리즘" 및 "서명 해시 알고리즘" 값이 SHA1 이하의 알고리즘으로 설정되어 있는 경우 - 취약하거나 보안수준이 낮은 HTTPS 프로토콜(SSL2.0/3.0, TLS1.0/1.1)을 이용하는 경우 - 보안 강도가 낮은 암호 알고리즘(RC4, MD5, DES, SHA1 등)을 허용하는 경우 - 취약한 키 교환 방식(RSA 등)을 지원하는 경우 - 취약한 HTTPS 재협상 방식을 허용하는 경우* * 재협상 방식 점검 결과 insecure client_initiated renegotiation 값이 supported로 설정되어 있는 경우 - HSTS를 적용하지 않아 SSL Strip 공격이 가능한 경우 - POODLE, Heartbleed 등 HTTPS 관련 취약점이 존재하는 경우 - 취약점이 존재하는 HTTPS 확장 모듈의 존재하는 경우 - 전방향 안전성(Forward Secrecy) 지원하지 않는 경우
거래정보 위·변조	계좌정보 변조 방지	계좌정보 무결성 검증 확인	☐ 전자금융거래 이용 중 계좌정보 위·변조 시 타인계좌 조회 및 위·변조된 계좌로 거래 가능 여부를 점검	- 입금이체 요청 시 네트워크 패킷 내 수취계좌정보 변조 후 이체가 가능한 경우 - 출금이체 요청 시 DOM 내 송금인정보 변조 후 이체가 가능한 경우 - 거래내역 조회 요청 시 메모리 내 계좌정보 변조 후 조회가 가능한 경우
	금액정보 변조 방지	금액정보 무결성 검증 확인	☐ 전자금융거래 이용 중 금액정보 위·변조 시 위·변조된 금액으로 거래 가능 여부를 점검	- 입금이체 요청 시 네트워크 패킷 내 금액정보 변조 후 이체가 가능한 경우 - 출금이체 요청 시 DOM 내 금액정보 변조 후 이체가 가능한 경우 - 포인트 충전 요청 시 메모리 내 금액정보 변조 후 충전이 가능한 경우 - 거래정보가 암호화되어 있으나 동일한 금액의 거래정보가 동일한 값으로 암호화되는 경우
		금액 한도 검증 확인	☐ 전자금융거래 이용 중 이체한도 범위를 벗어나는 금액(최대한도 초과, 음수 등)으로 거래 가능 여부를 점검	- 출금이체 요청 시 잔액을 초과하는 금액으로 이체가 가능한 경우 - 입금이체 요청 시 음수 금액으로 이체가 가능한 경우 - 포인트 충전 요청 시 충전 가능 금액을 초과하는 금액으로 충전이 가능한 경우
	거래정보 재사용 방지	거래정보 재사용 확인	☐ 전자금융거래 진행 시 이용된 거래정보를 재전송하여 재사용 가능 여부를 점검	- 출금이체 요청 시 획득한 네트워크 패킷을 재전송하여 정상 이체가 가능한 경우
서버 보안	서버 보안 적용	리다이렉트 기능을 이용한 피싱 가능성 확인	☐ 리다이렉트 기능이 존재하는 경우 URL 인자값을 임의의 페이지로 변경하여 이동 가능 여부를 점검	- 리다이렉트 URL(예: /login.jsp ?url=index.jsp)을 임의의 URL로 변조(예: login.jsp?url=https://www.xxx.com) 시 변조된 URL로 리다이렉트가 이루어지는 경우
		불필요한 메소드 허용 확인	☐ 불필요한 HTTP 메소드 허용 여부를 점검	- 최상위 경로에서 OPTIONS 메소드 요청 시 응답헤더의 메소드 허용목록 내 GET, POST를 제외한 메소드가 허용되어 악용할 수있는 경우(Allow: HEAD, DELETE, GET, PUT, TRACE, POST)
		외부 사이트에 의한 운영정보 노출 확인	☐ 검색엔진 등을 통해 핀테크서비스 관련 중요정보의 획득 가능 여부를 점검	- Google에서 점검 대상 서비스 검색(예: site:xxx.com filetype:hwp 등) 시 중요정보가 포함된 파일이 검색되는 경우
		SQL 인젝션 확인	☐ 이용자의 제어가 가능한 파라미터에 의해 SQL 쿼리문이 완성되는 점을 이용하여, 해당 파라미터 변조를 통해 SQL 쿼리문 조작 가능 여부를 점검	- 참 조건문(예: ' and '1'='1, and 1=1# 등)을 삽입 시 정상적인 결과가 출력되고, 거짓 조건문(예: ' and '1'='2, and 1=2# 등)을 삽입 시 이전과 상이한 결과가 출력되는 경우 - Union 구문(예: -1 union select 1,2 -- 등)을 삽입하여 응답값에 따라 질의문 실행 결과를 확인할 수 있는 경우 - 글번호에 싱글 쿼트(') 삽입 시 DBMS 에러메시지가 노출되는 경우
		디렉토리 목록화 확인	☐ 특정 디렉토리에 초기 페이지가 존재하지 않거나, 웹서버의 디렉토리 인덱싱 허용 설정 등으로 인한 해당 디렉토리 내 하위 디렉토리 및 파일 목록 노출 여부를 점검	- URL에 디렉토리 명(예: /mypage/)을 입력 시 하위 디렉토리 및 파일 정보가 노출되는 경우
		서버 운영정보 노출 확인	☐ 응답헤더 및 에러메시지 등에서 서버 운영정보(버전, 절대경로 등) 노출 여부를 점검	- 응답헤더 내 서버 버전정보가 포함(예: Server: Apache/2.4 등)되어 있는 경우 - 에러페이지 내 서버 운영정보(예: Apache/2.4, /var/www/fintech/xxx.jsp 등)가 노출되는 경우

분야	점검항목	세부 점검항목	점검항목 설명	주요 취약점 발생 사례
		크로스사이트 스크립팅(XSS) 확인	☐ 스크립트 전송 또는 업로드를 통해 응답값에 스크립트 포함 및 실행 가능 여부를 점검	- 검색 내용에 스크립트(예: "><script>alert(document.cookie)</script>, " onmouseover=alert(document.cookie) x=" 등을 삽입하여 검색 시 이용자 브라우저에서 스크립트가 실행되는 경우 - 게시물 내용에 스크립트(예: </textarea>, <svg/onload=alert(document.cookie)> 등을 삽입하여 업로드 후 게시물 확인 시 이용자 브라우저에서 스크립트가 실행되는 경우
		크로스사이트 리퀘스트 변조(CSRF) 확인	☐ 스크립트 구문 등을 업로드하여 타 이용자의 권한으로 실행 가능 여부를 점검	- 비밀번호 변경 스크립트(예: <script src="https://www.xxx.com/mypage /chg_pwd.jsp?new_pw=newpw"></script> 등)가 삽입된 게시물에 타 이용자가 접근 시 타 이용자의 권한으로 스크립트가 실행되어 비밀번호가 변경되는 경우
		파일 업로드 취약점 확인	☐ 파일 업로드 기능을 이용하여 서버 사이드 스크립트 파일(JSP, ASP 등) 업로드 및 실행 가능 여부를 점검	- JSP 기반으로 개발된 서비스에 JSP 파일을 업로드하여 경로 확인이 가능하며 접근 시 정상적으로 실행되는 경우 - HTML 파일을 업로드하여 경로 확인이 가능하며 접근 시 정상적으로 실행되는 경우 - 파일 업로드 용량 제한이 설정되어 있지 않은 경우
		파일 다운로드 취약점 확인	☐ 파일 다운로드 기능을 이용하여 접근이 허용된 디렉토리 외의 경로에 위치한 중요파일(소스코드, 설정파일 등) 다운로드 가능 여부를 점검	- 파일 다운로드 경로(예: /download.php?file=test.jpg)를 변조하여 중요파일 다운로드(예: /download.php?file=../dbconn.php)가 가능한 경우
		관리자 페이지 노출 확인	☐ 유추하기 쉬운 관리자 페이지(/admin, /manager 등) 경로에 접근 가능 여부를 점검	- 알려진 관리자 페이지 경로(예: /admin, /manager, /auth 등)에 접근 시 별도의 IP 통제가 이루어지지 않아 접속이 가능한 경우
		불필요 파일 노출 확인	☐ 잘 알려진 경로 대입 등을 통해 불필요 파일(테스트 파일, 백업 파일 등) 노출 여부를 점검	- 불필요 파일(예: .org, .bak, index1.jsp 등)이 존재하는 경우 - 소스코드 내 테스트 환경의 포트번호, URL 정보가 노출되는 경우
		(권고) 안전한 인증페이지 제공 확인	☐ OAuth 이용자 인증 과정에서 iframe을 이용하여 외부 도메인을 호출하는 경우 이용자의 인증페이지 식별*이 제한되어 피싱 위험 등이 존재하므로 안전한 방식**을 통한 인증페이지 출력을 권고 * 도메인 주소의 철자, 자물쇠 그림 확인 등 ** 인증페이지 팝업 등	- iframe을 이용하여 인증페이지를 출력하는 경우
오픈뱅킹 보안	오픈뱅킹 보안 적용	이용기관 주요 기능 수행 및 인증 적용 확인	☐ 하위사업자 운영 이용기관의 오픈뱅킹 주요 기능 직접 수행 및 추가인증 적용 여부를 점검	- 관련 문서를 제출하지 않을 경우 - 주요 기능 제공 여부를 확인할 수 없을 경우 - 이용기관이 제출한 사업계획서의 추가인증 방식이 적용되어 있지 않을 경우 - 이용기관이 제출한 사업계획서와 다른 추가인증 방식이 적용되어 있을 경우
		고정된 state 변수 부여 확인	☐ OAuth 이용자 인증 요청 시 가변적이고 추측이 어려운 state 변수값 부여 여부를 점검	- 오픈뱅킹 OAuth 이용 시 state 변수를 부여하지 않는 경우 - 오픈뱅킹 사용자인증(/oauth/2.0/authorize) 요청 시 state 변수에 단순하고 고정된 값(예: fintech)을 지속적으로 부여하는 경우 - 여카운트인포 사용자정보확인(/v2.0/accountinfo/identification) 요청 시 state 변수에 단순하고 고정된 값(예: fintech)을 지속적으로 부여하는 경우
		state 변수 무결성 검증 확인	☐ 인증 완료 요청시 state 변수값을 변조할 경우 state 변수에 대한 무결성 검증 여부를 점검	- state 변수를 변조하여 인증 완료 요청 시 정상적으로 인증이 완료되어 이용자 계좌가 등록되는 경우

분야	점검항목	세부 점검항목	점검항목 설명	주요 취약점 발생 사례
인증	인증 우회 방지 적용	이용자 인증정보 재사용 확인	☐ 이용자 인증 요청(로그인 요청 등) 시 사용된 인증정보를 획득 후 재전송하여 이용자 권한 획득 가능 여부를 점검	- 이용자 로그인 시 획득한 인증정보를 일정 시간 경과 후 재전송하여 이용자 권한 획득이 가능한 경우
		세션/토큰정보 재사용 확인	☐ 이용자 세션 및 토큰정보를 획득하여 별도의 환경에 강제 적용 후 해당 이용자 권한 획득 가능 여부를 점검	- 타 이용자의 세션정보를 별도의 IP 주소를 사용하는 PC에 강제 적용 시 타 이용자 권한 획득이 가능한 경우 - 패킷 헤더 및 페이로드 내 토큰 정보를 재사용하여 이용자 권한 획득이 가능한 경우
		불충분한 세션 만료 확인	☐ 이용자 인증 후 서비스 이용 없이 일정시간 경과 후 또는 이용자 로그아웃 요청 후 세션 종료 여부를 점검	- 세션 만료 시간이 설정되어 있지 않은 경우 - 로그인 이후 조작 없이 60분간 대기 후 또는 로그아웃 요청 후에도 세션이 만료되지 않아 기존 세션으로 이용자 권한이 필요한 페이지에 접근이 가능한 경우
		비밀번호 복잡도 검증 수준 확인	☐ 전자금융거래, 로그인 등의 절차 진행 시 요구되는 비밀번호의 복잡도 검증 수준을 점검* * 세부기준은 핀테크 보안점검 관리시스템의 FAQ를 참고	- 로그인 비밀번호 설정 시 복잡도 검증이 이루어지지 않아 'test1234' 등의 비밀번호 설정이 가능한 경우 - 이체 비밀번호 설정 시 복잡도 검증이 이루어지지 않아 '000000', '123456' 등의 비밀번호 설정이 가능한 경우
		비밀번호 오류 횟수 제한 확인	☐ 전자금융거래, 로그인 등의 절차 진행 시 이용자가 입력하는 비밀번호의 오류 횟수(5회) 제한 여부를 점검	- 잘못된 로그인 비밀번호를 입력하여 로그인 시도 및 비밀번호 변경 시도를 5회 반복 후 올바른 비밀번호를 입력할 시 정상적으로 로그인 및 변경이 이루어지는 경우 - 잘못된 이체 비밀번호를 입력하여 이체 시도 및 비밀번호 변경 시도를 5회 반복 후 올바른 비밀번호를 입력할 시 정상적으로 이체거래 및 변경이 이루어지는 경우
		불충분한 이용자 인증 확인	☐ 이용자 인증이 요구되는 페이지*에 접근 시 추가 인증 요구 여부 및 URL 직접 호출, 플로우 통제 우회 등을 통한 인증 우회 가능 여부를 점검 * 비밀번호 변경 페이지, 민감정보가 포함된 페이지 등	- 비밀번호 변경 기능 클릭 시 추가 인증 페이지로 연결되나, URL 직접 호출 시 추가 인증을 우회하여 접근이 가능한 경우 - 이용자 민감정보가 포함된 페이지 접근 시 클라이언트 스크립트로 추가 인증을 제어하여 해당 스크립트 삭제 시 추가 인증을 우회하여 접근이 가능한 경우 - 타 이용자 소유의 전화번호를 이용하여 SMS 인증 수행이 가능한 경우 - 1원 인증 시 횟수 제한이 없어 무차별 대입 공격이 가능한 경우 - 1회성 인증 URL 사용 이후 지속적으로 접근이 가능한 경우 - 비밀번호 변경 등 이용자 인증이 요구되는 페이지 접근 시 인증을 요구하지 않는 경우 - 1원 인증 유효 시간이 설정되어 있지 않거나 과도하게 설정된 경우 취약으로 판단(권고:15분 이하)
		부적절한 비밀번호 초기화 확인	☐ 비밀번호 복구 절차 이용 시 타 이용자의 비밀번호 획득, 변경 등의 가능 여부를 점검	- 비밀번호 초기화 시 '[계정명]+123' 등 유추 가능한 비밀번호가 발급되며, 이를 이용하여 타 이용자 비밀번호 초기화 후 로그인이 가능한 경우
		부적절한 인증정보 발급 확인	☐ 서버가 발급하는 인증정보를 추측하여 타 이용자의 권한을 획득할 수 없도록 인증정보의 적절성(가변성 및	- 타 이용자의 인증정보 예측이 가능하여 해당 인증정보를 통해 타 이용자 권한 획득이 가능한 경우

분야	점검항목	세부 점검항목	점검항목 설명	주요 취약점 발생 사례
			복잡성 등)을 점검	
		불충분한 인가 확인	☐ 파라미터 변조 등을 통한 타 이용자의 민감정보 노출 또는 권한 탈취가 이루어지지 않도록 접근 권한 검증 여부를 점검	- 개인정보 조회 시 이용자 식별정보를 변조하여 타 이용자 개인정보 조회가 가능한 경우(예: /mypage.jsp?uid=user1→user2) - 로그인 비밀번호 변경 시 전송되는 이용자 식별정보를 변조하여 타 이용자의 로그인 비밀번호 변경이 가능하고, 해당 비밀번호를 통해 로그인이 가능한 경우 - 공지사항의 상태 파라미터를 변조하여 게시글 수정이 가능한 경우(예: /notice.jsp?mode=view→modify)
		쿠키정보 변조 확인	☐ 쿠키정보를 이용한 이용자 검증 등의 절차가 존재하는 경우, 쿠키정보 변조를 통한 권한 탈취 등의 취약점 존재 여부를 점검	- 쿠키정보 내 계정을 타 이용자의 계정으로 변조(예: member=user1→user2)하여 타 이용자 권한 획득이 가능한 경우 - 쿠키정보 내 권한을 변조(예: auth=member→admin)하여 관리자 권한 획득이 가능한 경우
		이체성 거래 시 인증 적용 확인	☐ 이체성 거래 시 인증(예: 거래 비밀번호 확인) 적용 여부를 점검	- 이체성 거래* 처리 시 인증 없이 거래가 완료되는 경우 * 선불충전, 계좌이체, 결제, 선불충전금(전자지갑·가상계좌) 잔액의 증감 등 이용자의 전자금융재산에서 금전이 이동하는 거래 일체 - 서비스 로그인 절차가 존재하고 거래 인증수단이 적용되어 있으나, 거래 인증수단 기본 설정이 Off로 세팅되어 별도로 설정하지 않으면 인증이 적용되지 않는 경우 - 서비스 로그인 절차가 존재하지 않고 거래 인증수단 On/Off 설정이 가능한 경우 - 바코드 등 선불 충전금액의 결제 과정에서 부족한 금액에 대한 자동 충전 기능 적용 시, 자동 충전에 대한 사용자 인지 및 확인 과정이 없는 경우
		계좌 소유주 검증 확인	☐ 계좌 소유주 인증 시 계정 소유주와 일치 여부를 확인하지 않을 경우 검증절차 적용을 점검	- 인증하는 계좌의 소유주와 계정의 소유주가 일치하지 않음에도 계좌 인증이 정상 처리되는 경우 - 오픈뱅킹 솔루션 임대형 서비스에서, 하위사업자의 이용자 정보와 실제 계좌 소유주의 이용자 정보가 불일치함에도 서비스가 가능할 경우

2. 모바일 앱(Android, iOS)

분야	점검항목	세부 점검항목	점검항목 설명	주요 취약점 발생 사례
중요정보 보호	메모리 내 노출 방지	메모리 내 중요정보 평문 노출 확인	□ 중요정보 입력 또는 처리 과정 등에서 메모리 내 평문 (또는 쉽게 평문으로 변환 가능한 문자열) 노출 여부 를 점검	- 간편결제 비밀번호 입력 시 메모리 내 비밀번호가 평문 형태 또는 복호화가 가능한 인코딩 방식(예: Base64 등)으 로 노출되는 경우 - 주민등록번호 전송 이후 메모리 내 주민등록번호가 평문 형태 또는 복호화가 가능한 인코딩 방식(예: Base64 등) 으로 노출되는 경우로 노출되는 경우 - 중요정보가 포함된 파일(주민등록증, 운전면허증 등) 전송 이후 메모리 내 파일 원본 또는 복호화가 가능한 인코 딩 방식(예: Base64 등)으로 존재하는 경우 - 오픈뱅킹 이용 시 메모리 내 오픈뱅킹 관련 중요정보(access_token, client_secret 등)가 평문 형태 또는 복호화가 가능한 인코딩 방식(예: Base64 등)으로 노출되는 경우
	디버그 로그 내 노출 방지	디버그 로그 내 중요정보 평문 노출 확인	□ 디버그 로그 내 중요정보의 평문(또는 쉽게 평문으로 변환 가능한 문자열) 노출 여부를 점검	- 중요정보 입력 시 디버그 로그 내 비밀번호가 평문 또는 복호화가 가능한 인코딩 방식(예: Base64 등)으로 노출되는 경우 - 중요정보 전송 시 디버그 로그 내 비밀번호가 평문 또는 복호화가 가능한 인코딩 방식(예: Base64 등)으로 노출되는 경우 - 오픈뱅킹 이용 시 디버그 로그 내 오픈뱅킹 관련 중요정보(access_token, client_secret 등)가 평문 또는 복호화가 가능한 인코딩 방식(예: Base64 등) 형태로 노출되는 경우
	파일 내 노출 방지	단말 내 중요정보 평문 저장 확인	□ 이용자 단말의 점검대상 앱 관련 폴더 및 외부 저장소 내 중요정보의 평문 저장 여부를 점검	- 로그인 시 계정정보가 단말 내 파일에 평문 또는 복호화가 가능한 인코딩 방식(예: Base64 등)으로 저장되는 경우 - 신분증 업로드 완료 후 신분증 이미지 파일이 원본 형태 또는 복호화가 가능한 인코딩 방식(예: Base64 등)로 저장 되는 경우
	화면 내 노출 방지	화면 내 중요정보 평문 노출 확인	□ 중요정보의 화면 내 평문(원본) 노출 여부 및 화면캡 처를 통한 탈취 가능 여부를 점검	- 로그인 시 계정정보가 PC 내 파일에 평문 또는 복호화가 가능한 인코딩 방식(예: Base64 등)으로 저장되는 경우 - 신분증 업로드 완료 후 신분증 이미지 파일이 원본 형태로 저장되는 경우
		(iOS) 스냅샷 파일 내 중요정보 평문 노출 확인	□ 백그라운드 상태로 진입 시 저장되는 스냅샷 파일 내 중 요정보의 평문 노출 여부를 점검	- 주민등록번호 입력 후 백그라운드 상태로 진입 시 뒷자리가 평문으로 노출된 스냅샷 파일이 저장되는 경우 - 신분증 업로드 과정에서 백그라운드 상태로 진입 시 주민등록번호가 표시된 원본 이미지가 표시된 스냅샷 파일이 저장 되는 경우
	중요정보 암호화 전송	중요정보 송수신시 보호대책 적용 확인	□ 데이터 송수신시 중요정보가 평문(또는 쉽게 평문으로 변환 가능한 문자열, 신분증 등 중요정보가 포함된 이 미지, JWT 등)으로 노출되는 것을 방지하기 위한 보호 기능 적용 여부를 점검	- 중요정보 처리 요청/응답 시 패킷 내 중요정보가 평문 또는 복호화가 가능한 인코딩 방식(예: Base64 등)으로 전 송되는 경우 - 이용자 인증 시 오픈뱅킹 관련 중요정보(access_token, client_secret 등)가 네트워크 구간에서 암호화가 미적용 되 어 있는 경우 - 중요정보에 해당되는 이미지 처리 시 패킷 내 중요정보가 포함된 이미지가 평문 또는 복호화가 가능한 인코딩 방식 (예: Base64 등)으로 전송되어 해당 이미지를 추출할 수 있는 경우

분야	점검항목	세부 점검항목	점검항목 설명	주요 취약점 발생 사례
	네트워크 구간 암호화 적용	안전한 HTTPS 적용 확인	☐ 송·수신되는 중요정보를 보호하기 위해 통신구간 암호화(HTTPS) 적용 여부를 점검 ☐ 취약한 HTTPS 정책 사용 여부를 점검 ※ 취약한 HTTPS 정책 확인 및 조치 시 HTTPS 정책 검증 도구 (https://ssllabs.com, testssl 등) 참고	- 전자금융거래 관련 중요정보 전송 시 통신구간 암호화(HTTPS)가 미적용 되어있는 경우 - 서버 인증서의 유효기간이 만료되어 경고를 출력하는 경우 - 인증서의 “서명 알고리즘” 및 “서명 해시 알고리즘” 값이 SHA1 이하의 알고리즘으로 설정되어 있는 경우 - 취약하거나 보안수준이 낮은 HTTPS 프로토콜(SSL2.0/3.0, TLS1.0/1.1)을 이용하는 경우 - 보안 강도가 낮은 암호 알고리즘(RC4, MD5, DES, SHA1 등)을 허용하는 경우 - 취약한 키 교환 방식(RSA 등)을 지원하는 경우 - 취약한 HTTPS 재협상 방식을 허용하는 경우* * 재협상 방식 점검 결과 insecure client_initiated renegotiation 값이 supported로 설정되어 있는 경우 - HSTS를 적용하지 않아 SSL Strip 공격이 가능한 경우 - POODLE, Heartbleed 등 HTTPS 관련 취약점이 존재하는 경우 - 취약점이 존재하는 HTTPS 확장 모듈의 존재하는 경우 - 전방향 안전성(Forward Secrecy) 지원하지 않는 경우
거래정보 위·변조	계좌정보 변조 방지	계좌정보 무결성 검증 확인	☐ 전자금융거래 이용 중 계좌정보 위·변조 시 타인계좌 조회 및 위·변조된 계좌로 거래 가능 여부를 점검	- 입금이체 요청 시 네트워크 패킷 내 수취계좌정보 변조 후 이체가 가능한 경우 - 출금이체 요청 시 DOM 내 송금인정보 변조 후 이체가 가능한 경우 - 거래내역 조회 요청 시 메모리 내 계좌정보 변조 후 조회가 가능한 경우
	금액정보 변조 방지	금액정보 무결성 검증 확인	☐ 전자금융거래 이용 중 금액정보 위·변조 시 위·변조된 금액으로 거래 가능 여부를 점검	- 입금이체 요청 시 네트워크 패킷 내 금액정보 변조 후 이체가 가능한 경우 - 출금이체 요청 시 DOM 내 금액정보 변조 후 이체가 가능한 경우 - 포인트 충전 요청 시 메모리 내 금액정보 변조 후 충전이 가능한 경우 - 거래정보가 암호화되어 있으나 동일한 금액의 거래정보가 동일한 값으로 암호화되는 경우
		금액 한도 검증 확인	☐ 전자금융거래 이용 중 이체한도 범위를 벗어나는 금액(최대한도 초과, 음수 등)으로 거래 가능 여부를 점검	- 출금이체 요청 시 잔액을 초과하는 금액으로 이체가 가능한 경우 - 입금이체 요청 시 음수 금액으로 이체가 가능한 경우 - 포인트 충전 요청 시 충전 가능 금액을 초과하는 금액으로 충전이 가능한 경우
	거래정보 재사용 방지	거래정보 재사용 확인	☐ 전자금융거래 진행 시 이용된 거래정보를 재전송하여 재사용 가능 여부를 점검	- 출금이체 요청 시 획득한 네트워크 패킷을 재전송하여 정상 이체가 가능한 경우
클라이언트 보안	앱 위·변조 탐지 적용	앱 위·변조 탐지 기능 적용 확인	☐ 앱 설치파일 또는 설치된 앱의 실행파일 및 중요파일(관련 라이브러리 등)을 변조하여 앱 실행 시 정상 동작 여부를 점검	- 설치파일 변조 후 앱 설치 및 실행 시 전자금융거래가 정상적으로 실행되는 경우 - 중요파일 변조 후 앱을 실행하여 전자금융거래가 정상적으로 진행되는 경우 - 중요파일 변조 후 앱 실행 시에는 탐지되나, 앱 실행 후 중요파일을 변조하여 전자금융거래가 정상적으로 진행되는 경우
	해킹OS 탐지 적용	해킹OS 탐지 기능 적용 확인	☐ 루팅/탈옥된 단말에서 점검대상 앱 실행 시 정상 실행 가능 여부를 점검	- 루팅/탈옥된 단말에서 주요 기능이 정상적으로 실행되는 경우
	안티디버깅 적용	안티디버깅 적용 확인	☐ 디버거를 이용하여 앱 디버깅 후 주요 기능 정상 실행 가능 여부를 점검	- 전자금융거래 실행 중 디버거를 통해 프로세스 attach 후 정상적으로 진행이 가능한 경우 - AndroidManifest.xml 파일 내 android:debuggable="true"로 설정되어 있는 경우
	코드 난독화 적용	(Android) 코드 난독화 적용 확인	☐ 점검대상 앱의 디컴파일이 가능한 경우 복구된 소스코드 내 클래스명, 함수명 등의 노출 또는 중요 로직의 흐름 파악 가능 여부를 점검	- 소스코드 내 전자금융거래 관련 클래스명, 함수명 등이 평문 형태로 노출되는 경우 - 소스코드 내 루팅 탐지 로직의 흐름 파악이 가능한 경우
	안티바이러스 적용	(Android) 안티바이러스 적용 확인	☐ 점검대상 앱 실행 시 안티바이러스 프로그램 실행 여부 및 강제 종료 시 재실행 여부 등을 점검	- 앱 실행 시 안티바이러스 프로그램이 실행되지 않는 경우 - 전자금융거래 관련 기능 실행 중 안티바이러스 프로그램 강제 종료 시에도 안티바이러스 프로그램이 재실행되지 않고 전자금융거래가 정상적으로 진행되는 경우

분야	점검항목	세부 점검항목	점검항목 설명	주요 취약점 발생 사례
서버 보안	서버 보안 적용	리다이렉트 기능을 이용한 피싱 가능성 확인	☐ 리다이렉트 기능이 존재하는 경우 URL 인자값을 임의의 페이지로 변경하여 이동 가능 여부를 점검	- 리다이렉트 URL(예: /login.jsp ?rurl=index.jsp)을 임의의 URL로 변조(예: login.jsp?rurl=https://www.xxx.com) 시 변조된 URL로 리다이렉트가 이루어지는 경우
		불필요한 메소드 허용 확인	☐ 불필요한 HTTP 메소드 허용 여부를 점검	- 최상위 경로에서 OPTIONS 메소드 요청 시 응답헤더의 메소드 허용목록 내 GET, POST를 제외한 메소드가 허용되어 악용할 수 있는 경우(Allow: HEAD, DELETE, GET, PUT, TRACE, POST)
		외부 사이트에 의한 운영정보 노출 확인	☐ 검색엔진 등을 통해 핀테크서비스 관련 중요정보의 획득 가능 여부를 점검	- Google에서 점검 대상 서비스 검색(예: site:xxx.com filetype:hwp 등) 시 중요정보가 포함된 파일이 검색되는 경우
		SQL 인젝션 확인	☐ 이용자의 제어가 가능한 파라미터에 의해 SQL 쿼리문이 완성되는 점을 이용하여, 해당 파라미터 변조를 통해 SQL 쿼리문 조작 가능 여부를 점검	- 참 조건문(예: ' and '1'='1, and 1=1# 등)을 삽입 시 정상적인 결과가 출력되고, 거짓 조건문(예: ' and '1'='2, and 1=2# 등)을 삽입 시 이전과 상이한 결과가 출력되는 경우 - Union 구문(예: -1 union select 1,2 -- 등)을 삽입하여 응답값에 따라 질의문 실행 결과를 확인할 수 있는 경우 - 글번호에 싱글 쿼트(') 삽입 시 DBMS 에러메시지가 노출되는 경우
		디렉토리 목록화 확인	☐ 특정 디렉토리에 초기 페이지가 존재하지 않거나, 웹서버의 디렉토리 인덱싱 허용 설정 등으로 인한 해당 디렉토리 내 하위 디렉토리 및 파일 목록 노출 여부를 점검	- URL에 디렉토리 명(예: /mypage/)을 입력 시 하위 디렉토리 및 파일 정보가 노출되는 경우
		서버 운영정보 노출 확인	☐ 응답헤더 및 에러메시지 등에서 서버 운영정보(버전, 절대경로 등) 노출 여부를 점검	- 응답헤더 내 서버 버전정보가 포함(예: Server: Apache/2.4 등)되어 있는 경우 - 에러페이지 내 서버 운영정보(예: Apache/2.4, /var/www/fintech/xxx.jsp 등)가 노출되는 경우
		크로스사이트 스크립팅(XSS) 확인	☐ 스크립트 전송 또는 업로드를 통해 응답값에 스크립트 포함 및 실행 가능 여부를 점검	- 검색 내용에 스크립트(예: "><script>alert(document.cookie)</script>, " onmouseover=alert(document.cookie) x=" 등)를 삽입하여 검색 시 이용자 브라우저에서 스크립트가 실행되는 경우 - 게시글 내용에 스크립트(예: </textarea>, <svg/onload=alert(document.cookie)> 등)를 삽입하여 업로드 후 게시글 확인 시 이용자 브라우저에서 스크립트가 실행되는 경우
		크로스사이트 리퀘스트 변조(CSRF) 확인	☐ 스크립트 구문 등을 업로드하여 타 이용자의 권한으로 실행 가능 여부를 점검	- 비밀번호 변경 스크립트(예: <script src="https://www.xxx.com/mypage /chg_pwd.jsp?new_pw=newpw"></script> 등)가 삽입된 게시물에 타 이용자가 접근 시 타 이용자의 권한으로 스크립트가 실행되어 비밀번호가 변경되는 경우
		파일 업로드 취약점 확인	☐ 파일 업로드 기능을 이용하여 서버 사이드 스크립트 파일(JSP, ASP 등) 업로드 및 실행 가능 여부를 점검	- JSP 기반으로 개발된 서비스에 JSP 파일을 업로드하여 경로 확인이 가능하며 접근 시 정상적으로 실행되는 경우 - HTML 파일을 업로드하여 경로 확인이 가능하며 접근 시 정상적으로 실행되는 경우 - 파일 업로드 용량 제한이 설정되어 있지 않은 경우
		파일 다운로드 취약점 확인	☐ 파일 다운로드 기능을 이용하여 접근이 허용된 디렉토리 외의 경로에 위치한 중요파일(소스코드, 설정파일 등) 다운로드 가능 여부를 점검	- 파일 다운로드 경로(예: /download.php?file=test.jpg)를 변조하여 중요파일 다운로드(예: /download.php?file=../dbconn.php)가 가능한 경우
		관리자 페이지 노출 확인	☐ 유추하기 쉬운 관리자 페이지(/admin, /manager 등) 경로에 접근 가능 여부를 점검	- 알려진 관리자 페이지 경로(예: /admin, /manager, /auth 등)에 접근 시 별도의 IP 통제가 이루어지지 않아 접속이 가능한 경우
		불필요 파일 노출 확인	☐ 잘 알려진 경로 대입 등을 통해 불필요 파일(테스트 파일, 백업 파일 등) 노출 여부를 점검	- 불필요 파일(예: .org, .bak, index1.jsp 등)이 존재하는 경우 - 소스코드 내 테스트 환경의 포트번호, URL 정보가 노출 - 파일의 소스코드 상 테스트 및 스테이징 환경에 대한 경로 또는 주요 서비스 설정 정보의 주석 노출 등이 확인될 경우
		(권고) 안전한 인증페이지 제공 확인	☐ OAuth 이용자 인증 과정에서 웹뷰를 이용하여 외부 도메인을 호출하는 경우 이용자의 인증페이지 식별*이 제한되어 피싱 위험 등이 존재하므로 안전한 방식**을 통한 인증페이지 출력을 권고 * 도메인 주소의 철자, 자물쇠 그림 확인 등 ** 인앱 브라우저 탭(Android: Chrome Custom Tabs 등, iOS: SFSafariViewController 등)	- 웹뷰를 이용하여 인증페이지를 출력하는 경우

분야	점검항목	세부 점검항목	점검항목 설명	주요 취약점 발생 사례
오픈뱅킹 보안	오픈뱅킹 보안 적용	이용기관 주요 기능 수행 및 인증 적용 확인	☐ 하위사업자 운영 이용기관의 오픈뱅킹 주요 기능 직접 수행 및 추가인증 적용 여부를 점검	- 관련 문서를 제출하지 않을 경우 - 주요 기능 제공 여부를 확인할 수 없을 경우 - 이용기관이 제출한 사업계획서의 추가인증 방식이 적용되어 있지 않을 경우 - 이용기관이 제출한 사업계획서와 다른 추가인증 방식이 적용되어 있을 경우
		고정된 state 변수 부여 확인	☐ OAuth 이용자 인증 요청 시 가변적이고 추측이 어려 운 state 변수값 부여 여부를 점검	- 오픈뱅킹 OAuth 이용 시 state 변수를 부여하지 않는 경우 - 오픈뱅킹 사용자인증(/oauth/2.0/authorize) 요청 시 state 변수에 단순하고 고정된 값(예: fintech)을 지속적으로 부여 하는 경우 - 여카운트인포 사용자정보확인(/v2.0/accountinfo/identification) 요청 시 state 변수에 단순하고 고정된 값(예: fintech)을 지속적으로 부여하는 경우
		state 변수 무결성 검증 확인	☐ 인증 완료 요청시 state 변수값을 변조할 경우 state 변 수에 대한 무결성 검증 여부를 점검	- state 변수를 변조하여 인증 완료 요청 시 정상적으로 인증이 완료되어 이용자 계좌가 등록되는 경우
인증	인증 우회 방지 적용	이용자 인증정보 재사용 확인	☐ 이용자 인증 요청(로그인 요청 등) 시 사용된 인증정보 를 획득 후 재전송하여 이용자 권한 획득 가능 여부를 점검	- 이용자 로그인 시 획득한 인증정보를 일정 시간 경과 후 재전송하여 이용자 권한 획득이 가능한 경우
		세션정보 재사용 확인	☐ 이용자 세션정보를 획득하여 별도의 환경에 강제 적용 후 해당 이용자 권한 획득 가능 여부를 점검	- 타 이용자의 세션정보를 별도의 IP 주소를 사용하는 PC에 강제 적용 시 타 이용자 권한 획득이 가능한 경우 - 패킷 헤더 및 페이로드 내 토큰 정보를 재사용하여 이용자 권한 획득이 가능한 경우
		불충분한 세션 만료 확인	☐ 이용자 인증 후 서비스 이용 없이 일정시간 경과 후 또는 이용자 로그아웃 요청 후 세션 종료 여부를 점검	- 세션 만료 시간이 설정되어 있지 않은 경우 - 로그인 이후 조작 없이 60분간 대기 후 또는 로그아웃 요청 후에도 세션이 만료되지 않아 기존 세션으로 이용 자 권한이 필요한 페이지에 접근이 가능한 경우
		비밀번호 복잡도 검증 수준 확인	☐ 전자금융거래, 로그인 등의 절차 진행 시 요구되는 비 밀번호의 복잡도 검증 수준을 점검* * 세부기준은 핀테크 보안점검 관리시스템의 FAQ를 참고	- 로그인 비밀번호 설정 시 복잡도 검증이 이루어지지 않아 'test1234' 등의 비밀번호 설정이 가능한 경우 - 이체 비밀번호 설정 시 복잡도 검증이 이루어지지 않아 '000000', '123456' 등의 비밀번호 설정이 가능한 경우
		비밀번호 오류 횟수 제한 확인	☐ 전자금융거래, 로그인 등의 절차 진행 시 이용자가 입력 하는 비밀번호의 오류 횟수(5회) 제한 여부를 점검	- 잘못된 로그인 비밀번호를 입력하여 로그인 시도 및 비밀번호 변경 시도를 5회 반복 후 올바른 비밀번호를 입력할 시 정상적으로 로그인 및 변경이 이루어지는 경우 - 잘못된 이체 비밀번호를 입력하여 이체 시도 및 비밀번호 변경 시도를 5회 반복 후 올바른 비밀번호를 입력할 시 정상적으로 이체거래 및 변경이 이루어지는 경우
		불충분한 이용자 인증 확인	☐ 이용자 인증이 요구되는 화면*에 접근 시 추가 인증 요구 여부 및 URL 직접 호출, 플로우 통제 우회 등을 통한 인증 우회 가능 여부를 점검 * 비밀번호 변경 화면, 민감정보가 포함된 화면 등	- 비밀번호 변경 기능 클릭 시 추가 인증 페이지로 연결되나, URL 직접 호출 시 추가 인증을 우회하여 접근이 가 능한 경우 - 이용자 민감정보가 포함된 페이지 접근 시 클라이언트 스크립트로 추가 인증을 제어하여 해당 스크립트 삭제 시 추 가 인증을 우회하여 접근이 가능한 경우 - 타 이용자 소유의 전화번호를 이용하여 SMS 인증 수행이 가능한 경우 - 1원 인증 시 횟수 제한이 없어 무차별 대입 공격이 가능한 경우 - 1회성 인증 URL 사용 이후 지속적으로 접근이 가능한 경우 - 비밀번호 변경 등 이용자 인증이 요구되는 페이지 접근 시 인증을 요구하지 않는 경우 - 1원 인증 유효 시간이 설정되어 있지 않거나 과도하게 설정된 경우 취약으로 판단(권고:15분 이하)

분야	점검항목	세부 점검항목	점검항목 설명	주요 취약점 발생 사례
		부적절한 비밀번호 초기화 확인	☐ 비밀번호 복구 절차 이용 시 타 이용자의 비밀번호 획득, 변경 등의 가능 여부를 점검	- 비밀번호 초기화 시 '[계정명]+123' 등 유추 가능한 비밀번호가 발급되며, 이를 이용하여 타 이용자 비밀번호 초기화 후 로그인 가능한 경우
		부적절한 인증정보 발급 확인	☐ 서버가 발급하는 인증정보를 추측하여 타 이용자의 권한을 획득할 수 없도록 인증정보의 적절성(가변성 및 복잡성 등)을 점검	- 타 이용자의 인증정보 예측이 가능하여 해당 인증정보를 통해 타 이용자 권한 획득이 가능한 경우
		불충분한 인가 확인	☐ 파라미터 변조 등을 통한 타 이용자의 민감정보 노출 또는 권한 탈취가 이루어지지 않도록 접근 권한 검증 여부를 점검	- 개인정보 조회 시 사용자 식별정보를 변조하여 타 사용자 개인정보 조회가 가능한 경우(예: /mypage.jsp?uid=user1→user2) - 로그인 비밀번호 변경 시 전송되는 사용자 식별정보를 변조하여 타 사용자의 로그인 비밀번호 변경이 가능하고, 해당 비밀번호를 통해 로그인이 가능한 경우 - 공지사항의 상태 파라미터를 변조하여 게시물 수정이 가능한 경우(예: /notice.jsp?mode=view→modify)
		쿠키정보 변조 확인	☐ 쿠키정보를 이용한 사용자 검증 등의 절차가 존재하는 경우, 쿠키정보 변조를 통한 권한 탈취 등의 취약점 존재 여부를 점검	- 쿠키정보 내 계정을 타 이용자의 계정으로 변조(예: member=user1→user2)하여 타 사용자 권한 획득이 가능한 경우 <u>취약</u> 으로 판단 - 쿠키정보 내 권한을 변조(예: auth=member→admin)하여 관리자 권한 획득이 가능한 경우 <u>취약</u> 으로 판단
		화면 강제실행 확인	☐ 화면 강제 실행을 통한 인증절차 우회 가능 여부를 점검	- AndroidManifest.xml에서 확인한 금융정보조회 Activity를 adb로 강제실행시켜 인증절차를 거치지 않고 금융정보 확인이 가능한 경우 - cycript로 확인한 비밀번호 변경 Controller를 cycript로 강제실행시켜 인증절차를 거치지 않고 화면이 출력되어 비밀번호 변경이 가능한 경우
		인증파일 변조 확인	☐ 인증파일 변조를 통한 인증절차 우회 가능 여부를 점검	- 인증파일 삭제 후 인증절차 진입 시 비밀번호 설정 화면이 출력되는 경우 - 타 단말로 인증파일 복사 후 인증절차 진입 시 인증절차를 통과하여 서비스 이용이 가능한 경우
		이체성 거래 시 인증 적용 확인	☐ 이체성 거래 시 인증(예: 거래 비밀번호 확인) 적용 여부를 점검	- 이체성 거래* 처리 시 인증 없이 거래가 완료되는 경우 * 선불충전, 계좌이체, 결제, 선불충전금(전자지갑·가상계좌) 잔액의 증감 등 이용자의 전자금융재산에서 금전이 이동하는 거래 일체 - 서비스 로그인 절차가 존재하고 거래 인증수단이 적용되어 있으나, 거래 인증수단 기본 설정이 Off로 세팅되어 별도로 설정하지 않으면 인증이 적용되지 않는 경우 - 서비스 로그인 절차가 존재하지 않고 거래 인증수단 On/Off 설정이 가능한 경우 - 바코드 등 선불 충전금액의 결제 과정에서 부족한 금액에 대한 자동 충전 기능 적용 시, 자동 충전에 대한 사용자 인지 및 확인 과정이 없는 경우
		계좌 소유주 검증 확인	☐ 계좌 소유주 인증 시 계정 소유주와 일치 여부를 확인하지 않을 경우 검증절차 적용을 점검	- 인증하는 계좌의 소유주와 계정의 소유주가 일치하지 않음에도 계좌 인증이 정상 처리되는 경우 - 오픈뱅킹 솔루션 임대형 서비스에서, 하위사업자의 사용자 정보와 실제 계좌 소유주의 사용자 정보가 불일치함에도 서비스가 가능할 경우

핀테크서비스 취약점 점검 안내서 (오픈뱅킹)

발행일 : 2026년 2월

발행인 : 박 상 원

발행처 : 금융보안원

주 소 : 경기도 용인시 수지구 대지로 132
